

CORSO DI CYBERSECURITY – EPICODE

BUILD WEEK

Traccia Extra 1 – Sorgente del Malware: Analisi Forense di Mydoom.A

Build Week

A cura di:

**Akatsuki: Nicola Madonna, Lorenzo
Rizzuti, Donato Barbetta, Alex Tarantino,
Leonardo Onori**

Epicode

7 settembre 2026

Indice

1	Riassunto	2
2	Obiettivi	2
3	Configurazione del Laboratorio	3
3.1	Ambiente di laboratorio	3
3.2	Configurazione di rete	3
3.3	Metodologia	3
3.4	Verifica	3
4	Analisi dei Dati Raccolti	4
4.1	Identificazione del campione	4
4.2	Struttura dell'archivio sorgente	6
4.3	Mappa architetturale dei moduli	7
4.4	Comportamento noto pubblicamente di Mydoom.A	8
4.5	Scenario di intelligence: valutazione di una nuova variante	9
5	Conclusioni	10

1 Riassunto

Questo report documenta l'analisi forense statica dell'archivio `Win32.Mydoom.a.7z`, contenente il codice sorgente del worm Mydoom.A (2004), scaricato dal repository GitHub indicato nella traccia. L'analisi è stata condotta in ambiente isolato FLARE-VM utilizzando strumenti di identificazione e ispezione file (calcolo hash, Detect It Easy, CFF Explorer, estrazione stringhe) e correlata con i risultati di VirusTotal. L'archivio è stato inoltre estratto per esaminarne la struttura interna e ricostruire una mappa architetturale dei moduli sulla base dei nomi dei file e della letteratura pubblica esistente su Mydoom. È stato inoltre predisposto un ambiente di analisi dinamica isolata (FakeNet-NG) per verificare l'assenza di generazione di traffico malevolo, dato che il codice sorgente non è stato compilato né eseguito. Il report si chiude con uno scenario di intelligence che propone un framework per valutare rapidamente eventuali nuove varianti del malware.

2 Obiettivi

- Identificare univocamente il campione tramite calcolo e verifica degli hash crittografici.
- Analizzare il tipo di file e la struttura del contenitore tramite Detect It Easy e CFF Explorer.
- Ricostruire l'architettura del malware a partire dalla struttura del codice sorgente, senza eseguire o compilare il payload.
- Correlare i risultati con la reputazione pubblica del campione su VirusTotal.
- Valutare, tramite uno scenario di intelligence, come identificare rapidamente eventuali modifiche o aggiornamenti rispetto alla versione originale in una nuova variante ipotetica.

3 Configurazione del Laboratorio

3.1 Ambiente di laboratorio

L'analisi è stata condotta su una macchina virtuale FLARE-VM (Windows 10, versione build 2009, architettura x86_64), predisposta con i tool di reverse engineering necessari: Detect It Easy (DIE) v3.10, CFF Explorer VIII, un tool di calcolo hash (MD5/SHA-1), un editor esadecimale (HxD) e uno strumento di estrazione stringhe. È inoltre disponibile, sulla stessa rete isolata, una macchina Kali Linux, non utilizzata direttamente in questa fase in quanto l'esercizio non ha richiesto l'esecuzione del campione.

3.2 Configurazione di rete

L'adattatore di rete della FLARE-VM è stato mantenuto in modalità **Host-only**, per garantire che nessun pacchetto potesse raggiungere una rete reale durante le fasi di ispezione del file. Questa precauzione resta valida indipendentemente dal fatto che, come descritto in Sezione 4.6, il payload non sia mai stato compilato né eseguito.

3.3 Metodologia

Il file fornito dalla traccia (`Win32.Mydoom.a.7z`) è un archivio 7-Zip contenente il codice sorgente del worm, non un eseguibile. Di conseguenza l'analisi si è articolata in due fasi distinte:

- **Analisi del contenitore:** hashing, identificazione del tipo di file e ispezione tramite CFF Explorer sull'archivio `.7z` così come fornito.
- **Analisi della struttura sorgente:** estrazione dell'archivio ed esame dell'organizzazione dei file (nomi, dimensioni, estensioni) per ricostruire l'architettura del malware.

Per policy interna del laboratorio, il codice sorgente non è stato compilato: farlo avrebbe prodotto un binario Mydoom realmente funzionante, con rischio di propagazione ed esecuzione di un payload attivo anche in un ambiente nominalmente isolato. L'analisi architeturale si basa quindi sui nomi dei moduli, sulla struttura del progetto e sulla letteratura pubblica esistente su Mydoom.A, non sulla lettura del codice implementativo.

3.4 Verifica

La corrispondenza tra il file analizzato localmente e il campione noto è stata verificata confrontando gli hash calcolati in locale con quelli riportati da VirusTotal per lo stesso file.

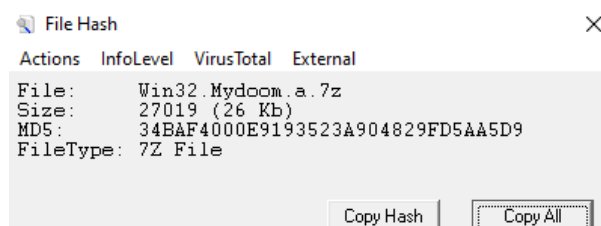


Figura 1: Calcolo dell'hash MD5 dell'archivio `Win32.Mydoom.a.7z`.

4 Analisi dei Dati Raccolti

Di seguito sono riportati i risultati emersi dalle diverse fasi di analisi, dall'identificazione del campione alla ricostruzione della sua architettura interna.

4.1 Identificazione del campione

Il calcolo degli hash sull'archivio ha prodotto i seguenti valori, confermati sia localmente (tool hash e CFF Explorer) sia da VirusTotal:

Tabella 1: Identificativi hash e proprietà di base del campione.

Proprietà	Valore
Nome file	Win32.Mydoom.a.7z
Dimensione	27.019 byte (26,39 KiB)
MD5	34BAF4000E919352 3A904829FD5AA5D9
SHA-1	AFDDB0BC79EDC69C 142F79CCAA672463 82789C7A
SHA-256	1be75d002e1f21f9 aa4b4021fc403a78 9553039a6d3f7669 93f5a0307e35b1c9
Tipo file	7-Zip archive, versione 0.4

Detect It Easy conferma che il file è un contenitore 7-Zip(0.4) e non un eseguibile Portable Executable (PE); questo è stato confermato anche da CFF Explorer, che segnala esplicitamente “Not a Portable Executable” per lo stesso file.

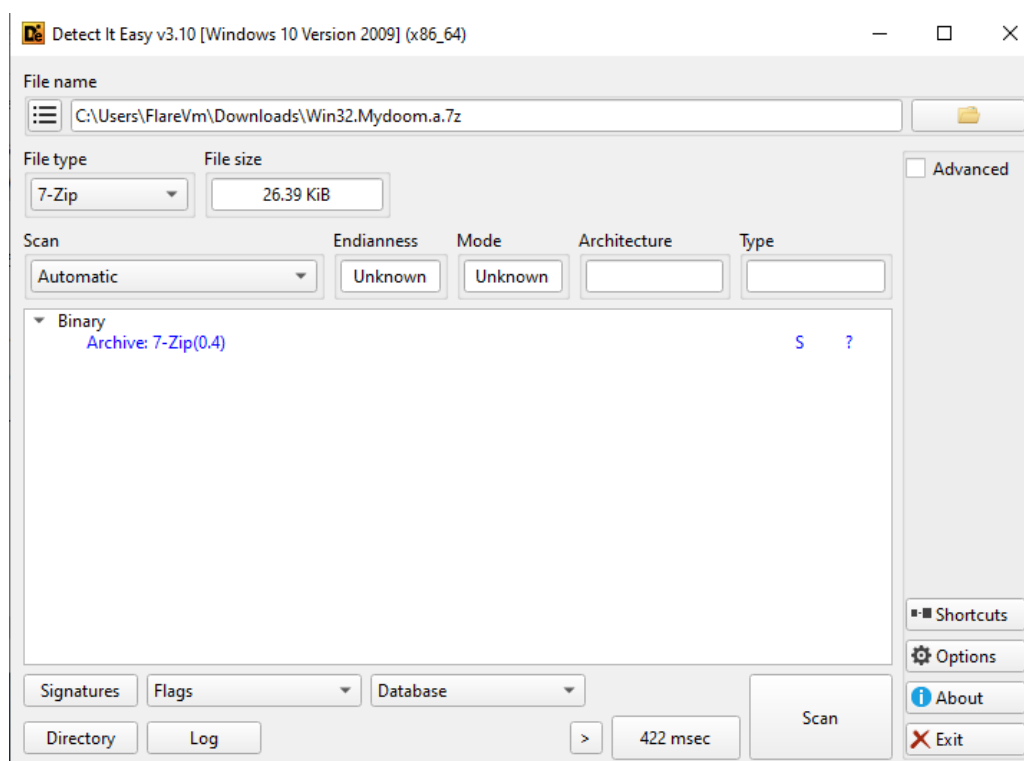


Figura 2: Identificazione del tipo di file tramite Detect It Easy.

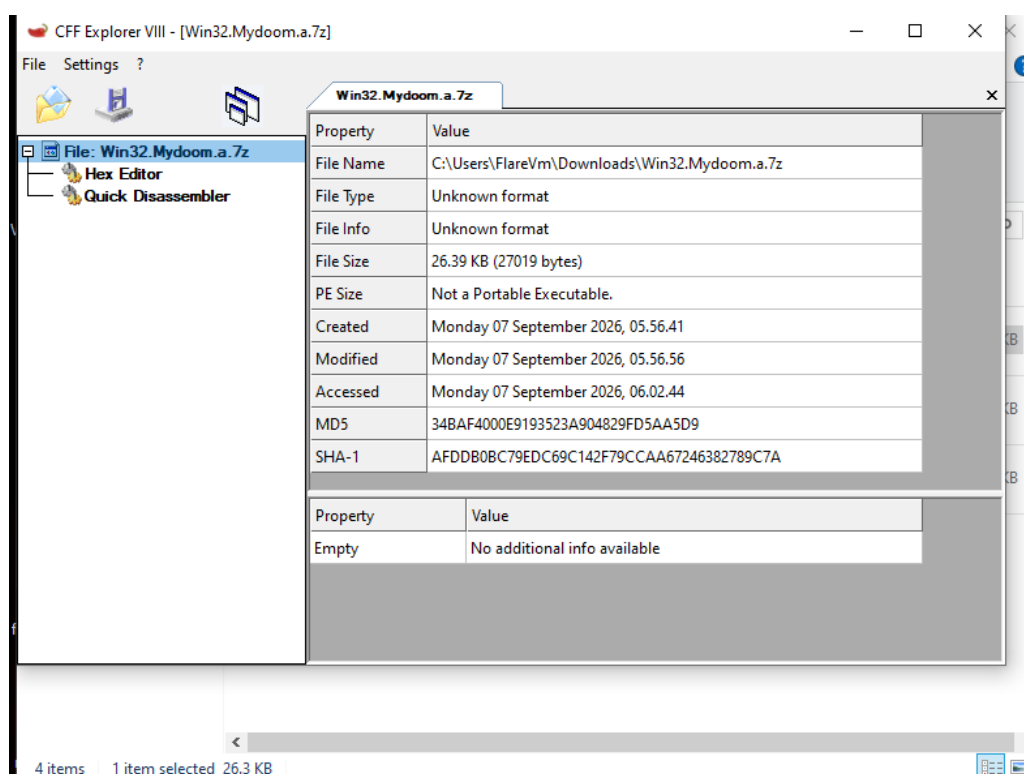


Figura 3: Proprietà del file in CFF Explorer: formato non riconosciuto come PE, hash MD5/SHA-1 coerenti con quanto calcolato in precedenza.

Il riscontro su VirusTotal conferma l'identità del campione e ne evidenzia la storicità:

la prima sottomissione registrata risale al 18 novembre 2020, con analisi più recente ad agosto 2026. Il punteggio di rilevamento è di **2 vendor su 56**, un valore basso ma coerente con la natura del file: si tratta di un archivio di codice sorgente, non di un payload compilato, e la maggior parte dei motori antivirus non è progettata per segnalare come malevolo del testo C non compilato. VirusTotal riporta inoltre nomi alternativi associati allo stesso hash, tra cui **Win32.Mydoom.akir4d.7z**, **Win32.Mydoom.a(1).7z** e, curiosamente, **5bi2ql.exe** – probabile rinominazione da parte di un utente terzo in fase di sottomissione, non indicativa di un formato diverso dall'archivio 7-Zip originale.

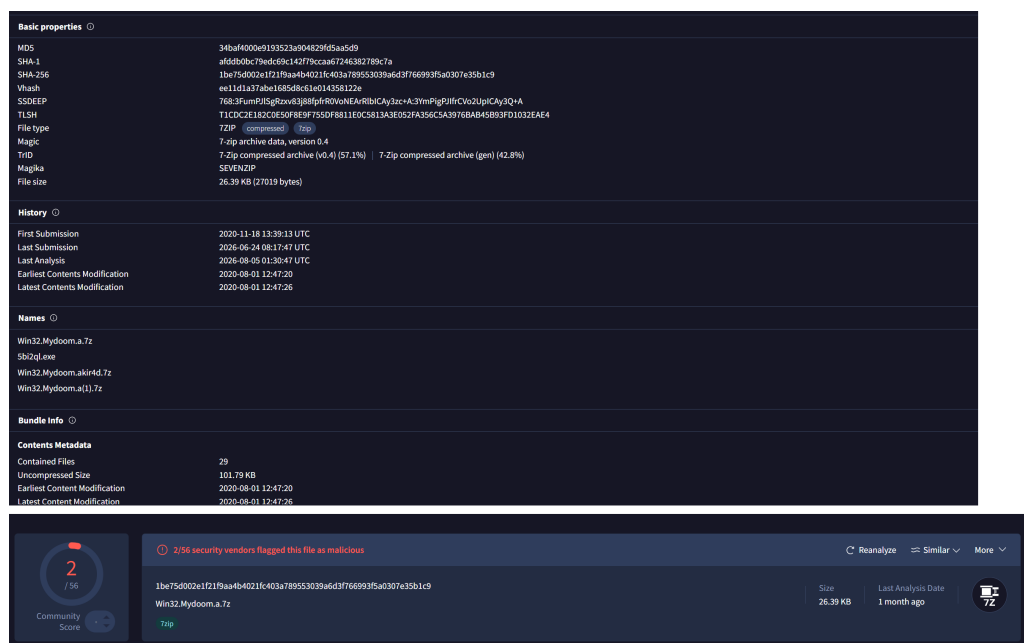


Figura 4: Panoramica VirusTotal: hash, cronologia delle sottomissioni e punteggio di rilevamento (2/56).

4.2 Struttura dell'archivio sorgente

L'estrazione dell'archivio rivela 29 file per un totale di 101,79 KB non compressi, organizzati come segue per estensione:

Tabella 2: Composizione dell'archivio per tipo di file (fonte: VirusTotal e ispezione diretta).

Estensione	Numero di file
.c	15
.h	8
.cpp	1
.rc	1
.ico	1
.txt	1
makefile / altri senza estensione	2

L'ispezione diretta della cartella estratta conferma la presenza, oltre ai singoli moduli `.c/.h`, di due sottocartelle (`work/` e `xproxy/`) e di un file `_readme.txt`. Questi tre elementi non fanno parte della struttura originale del 2004 documentata pubblicamente per Mydoom.A e sono probabilmente artefatti introdotti dal repository terzo da cui il campione è stato ridistribuito, piuttosto che parte del payload stesso; il loro contenuto non è stato ispezionato in questa sede.

work	8/1/2020 5:47 AM	File folder	
xproxy	8/1/2020 5:47 AM	File folder	
_readme.txt	8/1/2020 5:47 AM	Text Document	1 KB
lib.c	8/1/2020 5:47 AM	C Source File	8 KB
lib.h	8/1/2020 5:47 AM	C Header Source F...	1 KB
main.c	8/1/2020 5:47 AM	C Source File	8 KB
makefile	8/1/2020 5:47 AM	File	1 KB
massmail.c	8/1/2020 5:47 AM	C Source File	15 KB
massmail.h	8/1/2020 5:47 AM	C Header Source F...	1 KB
msg.c	8/1/2020 5:47 AM	C Source File	12 KB
msg.h	8/1/2020 5:47 AM	C Header Source F...	1 KB
p2p.c	8/1/2020 5:47 AM	C Source File	2 KB
resource.ico	8/1/2020 5:47 AM	Icon	1 KB
resource.rc	8/1/2020 5:47 AM	RC File	1 KB
scan.c	8/1/2020 5:47 AM	C Source File	12 KB
scan.h	8/1/2020 5:47 AM	C Header Source F...	1 KB
sco.c	8/1/2020 5:47 AM	C Source File	3 KB
sco.h	8/1/2020 5:47 AM	C Header Source F...	1 KB
xdns.c	8/1/2020 5:47 AM	C Source File	11 KB
xdns.h	8/1/2020 5:47 AM	C Header Source F...	1 KB
xsmtp.c	8/1/2020 5:47 AM	C Source File	9 KB
xsmtp.h	8/1/2020 5:47 AM	C Header Source F...	1 KB
zipstore.c	8/1/2020 5:47 AM	C Source File	9 KB
zipstore.h	8/1/2020 5:47 AM	C Header Source F...	1 KB

Figura 5: Struttura dei file dopo l'estrazione dell'archivio.

Bundled Files (29)			
Scanned	Detections	File type	Name
2020-02-12	0 / 59	C	Win32.Mydoom.a/lib.c
2021-12-14	0 / 57	C	Win32.Mydoom.a/lib.h
2020-02-06	0 / 58	C	Win32.Mydoom.a/main.c
2019-08-20	0 / 56	Text	Win32.Mydoom.a/makefile
2019-08-20	0 / 57	C	Win32.Mydoom.a/massmail.c
2021-12-13	0 / 57	C	Win32.Mydoom.a/massmail.h
2020-02-10	0 / 60	C	Win32.Mydoom.a/msg.c
2019-08-20	0 / 58	C	Win32.Mydoom.a/msg.h
2019-08-20	0 / 57	C	Win32.Mydoom.a/p2p.c
2024-12-08	0 / 61	ICO	Win32.Mydoom.a/resource.ico

Figura 6: Elenco dei file contenuti nell'archivio secondo VirusTotal, con relativo detection score individuale (0 su un massimo di 56–61 vendor per i singoli sorgenti).

4.3 Mappa architetturale dei moduli

Sulla base dei nomi dei file e della documentazione pubblica esistente su Mydoom.A¹, è possibile associare a ciascun modulo una funzione presunta, senza che questo derivi dalla lettura del codice implementativo:

¹Fonti: Symantec, Panda Security (Virus Encyclopedia), Wikipedia – voce “Mydoom”; vedere i riferimenti citati nelle note successive.

Tabella 3: Mappa architetturale dei moduli sorgente, basata su nomenclatura e letteratura pubblica.

Modulo	Funzione presunta
main.c	Punto di ingresso, orchestrazione degli altri moduli
lib.c / lib.h	Funzioni di libreria condivise
massmail.c / massmail.h	Motore di invio massivo delle email infette
msg.c / msg.h	Gestione dei template dei messaggi (oggetto, corpo, allegato)
xsmtp.c / xsmtp.h	Motore SMTP proprietario per l'invio autonomo delle email
xdns.c / xdns.h	Risoluzione DNS proprietaria (ricerca dei server di posta)
zipstore.c / zipstore.h	Gestione del payload compresso allegato alle email
scan.c / scan.h	Raccolta di indirizzi email dal sistema infetto
sco.c / sco.h	Modulo di supporto correlato alla scansione
p2p.c	Componente di comunicazione P2P / backdoor
resource.ico / resource.rc	Risorse Windows (icona, metadati) del binario compilato

4.4 Comportamento noto pubblicamente di Mydoom.A

Le informazioni seguenti sono tratte da fonti pubbliche e storiche su Mydoom, non dall'ispezione diretta del codice sorgente di questo esercizio, e sono riportate a scopo di contestualizzazione.

Mydoom (noto anche come Novarg o Mimail.R) è apparso per la prima volta il 26 gennaio 2004 e in alcuni momenti di picco è stato responsabile di circa un'email su cinque a livello globale, rendendolo tra i worm a diffusione più rapida mai registrati². Il worm si propagava principalmente via email, mascherandosi da notifica di mancata consegna di un messaggio (*delivery failure notice*), e utilizzava un proprio motore SMTP per inviarsi autonomamente agli indirizzi raccolti da file locali sul sistema infetto, aggirando così il client di posta predefinito³. Una copia del worm veniva inoltre depositata nella cartella condivisa dell'applicazione P2P Kazaa, per favorire una seconda via di diffusione⁴.

La variante originale (Mydoom.A) installava una backdoor tramite il file `SHIMGAPI.DLL`, depositato nella cartella di sistema e lanciato come processo figlio di Windows Explorer, in ascolto sulla prima porta TCP libera nell'intervallo 3127–3198⁵. Tale backdoor consentiva accesso remoto al sistema infetto e fungeva da server proxy TCP. Il payload includeva inoltre un attacco DDoS contro il sito `www.sco.com`, programmato per attivarsi tra il 1° e il 12 febbraio 2004 tramite richieste `GET` ripetute a intervalli di circa 1024 millisecondi⁶; una variante successiva (Mydoom.B) aggiungeva un attacco analogo contro `microsoft.com` a partire dal 3 febbraio 2004 e bloccava l'accesso a diversi siti di vendor di sicurezza⁷. Questi elementi storici sono coerenti con la mappa architetturale ricostruita in Tabella 3: i moduli

² *Wikipedia*, voce “Mydoom.” en.wikipedia.org/wiki/Mydoom.

³ Harrisburg University IT Help, “The MyDoom Worm: A Retrospective.” ithelp.harrisburgu.edu.

⁴ Xataka, “Mydoom, el peor virus informático de la historia.” xataka.com.

⁵ *Wikipedia*, voce “Mydoom.” en.wikipedia.org/wiki/Mydoom.

⁶ Panda Security, Virus Encyclopedia, voce “Mydoom.A.” pandasecurity.com.

⁷ *Wikipedia*, voce “Mydoom.” en.wikipedia.org/wiki/Mydoom.

`massmail`, `xsmtp` e `scan` corrispondono al motore di mass-mailing documentato, mentre `p2p.c` è coerente con la componente di comunicazione remota/backdoor storicamente riportata.

4.5 Scenario di intelligence: valutazione di una nuova variante

Nell'ipotesi in cui l'intelligence rilevi una nuova variante di Mydoom, la baseline costruita in questa analisi (hash, struttura dei moduli, comportamento storico noto) permette di impostare un confronto rapido, focalizzato sui seguenti indicatori:

- **Hash e fingerprint:** un nuovo hash non presente nei database di reputazione (VirusTotal) è il primo segnale di una variante non ancora classificata.
- **Infrastruttura di comando e controllo:** verificare se il modulo di comunicazione remota (equivalente a `p2p.c`) utilizza ancora un intervallo di porte fisso e locale (come 3127–3198) oppure indirizzi/domini esterni hardcoded o generati dinamicamente (DGA), segno di un'infrastruttura C2 aggiornata.
- **Vettori di propagazione:** confrontare se il set di moduli di propagazione è rimasto invariato (email + P2P) o se sono stati aggiunti nuovi canali (es. condivisioni di rete, dispositivi rimovibili, protocolli di messaggistica moderni).
- **Tecniche di evasione:** verificare la presenza di packing/offuscamento sul binario compilato (assente nel sorgente originale) tramite strumenti come Detect It Easy, e confrontare firme e sezioni PE con un campione compilato di riferimento.
- **Liste di esclusione:** il codice originale evitava di colpire alcuni domini universitari e aziendali; una variazione in questa lista può indicare un nuovo target o autore.
- **Timestamp di compilazione e metadati PE:** utili per stimare la data di creazione della variante e confrontarla con la timeline nota del malware originale.

Questo framework consente di rispondere rapidamente a una nuova minaccia sviluppando un confronto strutturato con la baseline, senza necessità di rieseguire l'intero processo di analisi da zero.

5 Conclusioni

L'analisi ha permesso di identificare univocamente il campione `Win32.Mydoom.a.7z` tramite hashing e riscontro su VirusTotal, e di ricostruirne l'architettura interna a partire dalla struttura del codice sorgente, senza necessità di compilare o eseguire il payload. La mappa dei moduli ottenuta (mass-mailing, motore SMTP proprietario, raccolta indirizzi, componente P2P/backdoor) risulta coerente con quanto storicamente documentato su Mydoom.A dalla comunità di sicurezza, confermando l'utilità di un'analisi basata su nomenclatura e metadati anche in assenza di accesso al comportamento implementativo del codice.

Un dato interessante emerso è il basso detection score su VirusTotal (2/56): questo evidenzia come i motori antivirus tradizionali siano ottimizzati per rilevare payload compilati piuttosto che codice sorgente in chiaro, un limite rilevante da tenere presente quando si valuta la pericolosità di un file basandosi unicamente sul punteggio aggregato di un aggregatore come VirusTotal.

Come sviluppo futuro, un'analisi più approfondita richiederebbe la disponibilità di un campione compilato (piuttosto che il solo sorgente) da esaminare in un ambiente di sandboxing dedicato e pienamente contenuto, permettendo di osservare concretamente il traffico di rete generato e di verificare quanto delle funzionalità storicamente documentate risulti ancora operativo su un sistema Windows moderno.